

Plantilla de Reporte Ejecutivo – GQM + PRAGMATIC + PASTA+STRIDE

Estructura orientada a una presentación tipo PowerPoint para responsables políticos, reguladores y alta dirección.

Diapositiva 1 – Portada

- Título: “Indicadores nacionales de ciberseguridad basados en Threat Modeling (GQM + PRAGMATIC)”
- Subtítulo: Resultados preliminares / Año / Alcance
- Logo(s): organismo(s) responsable(s)

Diapositiva 2 – Por qué otro cuadro de mando (y por qué este sí importa)

- Problema actual: métricas dispersas, poco alineadas con objetivos reales.
- Propuesta: marco GQM+PRAGMATIC aplicado a PASTA+STRIDE y objetivos nacionales.
- Beneficios: trazabilidad, comparabilidad internacional, foco en resiliencia y eficiencia.[web:21][web:56]

Diapositiva 3 – Marco conceptual

- GQM: de objetivos a preguntas y métricas.[web:45][web:46][web:51]
- PRAGMATIC: cómo escoger métricas que valgan la pena.[web:50][web:52][web:58]
- PASTA+STRIDE: fuente de indicadores técnicos de amenazas y riesgos.[web:18][web:28][web:39]

Breve diagrama mostrando la cadena: Objetivos – Preguntas – Métricas – Evaluación PRAGMATIC.

Diapositiva 4 – Objetivos estratégicos (G1-G4)

- G1: Proteger infraestructuras y servicios esenciales.
- G2: Aumentar la madurez basada en riesgo.
- G3: Mejorar la resiliencia y la recuperación.
- G4: Optimizar la eficiencia económica de la inversión.

Indicar relación con NIS2, Plan Nacional, España Digital.[web:21][web:27][web:30]

Diapositiva 5 – Métricas núcleo (Núcleo duro PRAGMATIC)

Presentar una tabla resumida con las métricas mejor puntuadas:

- M1.3: % de proyectos críticos con Threat Modeling en diseño.
- M2.3.x: Tendencia anual de incidentes STRIDE.
- M3.3: % de ejercicios con planes de acción implementados.
- M4.1: MTTR crítico.
- M5.3: % de entidades que usan Threat Modeling para decisiones de inversión/ROI.

Subrayar que estas métricas están “doblemente justificadas”: por objetivos (GQM) y por utilidad práctica (PRAGMATIC).

Diapositiva 6 – Resultados agregados (ejemplo)

- Gráfico de barras o radar mostrando valores medios nacionales / por sector para las métricas núcleo.
- Comentarios: sectores más avanzados, brechas notables, tendencias preocupantes.

Diapositiva 7 – Caso de uso: MTTR crítico y ejercicios de simulación

- Relación entre M3.1/M3.3 (simulaciones) y M4.1 (MTTR).
- Si existe correlación: mostrar que más y mejores ejercicios se asocian con menor tiempo de recuperación.
- Implicación: los ejercicios basados en PASTA no son teatro; reducen daño real.

Diapositiva 8 – Caso de uso: madurez vs. incidentes STRIDE

- Relación entre cobertura de Threat Modeling (M1.1/M1.3) y tendencia STRIDE (M2.3.x).
- Mensaje: dónde se modela bien, las curvas de incidentes tienden a aplanarse antes.

Diapositiva 9 – Cálculo de IGM y ROI (visión simplificada)

- Explicar que a partir de métricas normalizadas se construye un IGM por sector/organización.
- Mostrar ejemplo de cómo una mejora de X puntos de IGM se asocia a reducción estimada de riesgo y a un ROI positivo, utilizando la plantilla de Excel.[web:48][web:51]

Diapositiva 10 – Recomendaciones de política pública

- Integrar el marco GQM+PRAGMATIC en la revisión del Plan Nacional de Ciberseguridad y guías de INCIBE/CCN.
- Establecer un set mínimo obligatorio de métricas para operadores esenciales.
- Incentivar la mejora de IGM mediante programas de apoyo, formación y financiación.

Diapositiva 11 – Recomendaciones para organizaciones

- Adoptar GQM+PRAGMATIC internamente para limpiar y priorizar métricas.
- Usar PASTA+STRIDE no sólo para hablar con auditores, sino con Finanzas y el Consejo.
- Vincular, de verdad, ejercicios de simulación con planes de acción e inversión.

Diapositiva 12 – Limitaciones y siguientes pasos

- Reconocer limitaciones de datos (sub-reporting, auto-declaración, heterogeneidad sectorial).
- Proponer hoja de ruta de 3–5 años para mejorar la calidad y profundidad de las métricas.
- Invitar a colaboración entre organismos, sectores y comunidad técnica.

Diapositiva 13 – Cierre

Mensaje final:

“Si sabemos qué queremos lograr (G), sabemos qué debemos preguntar (Q) y escogemos bien qué

medimos (M), la ciberseguridad deja de ser un acto de fe y se convierte en una política pública basada en evidencias. Y eso, en un país con más de 100.000 ataques al año, no es un lujo: es pura supervivencia informada.”[web:21]